

Identity Sprawl & Privilege Abuse Detection

Problem Statement

Which Organizations Are Most at Risk?

Organizations using hybrid identity environments, especially in Finance, Healthcare, and SaaS sectors, are highly vulnerable to identity-based attacks. A single compromised administrative account can provide access to multiple systems, exposing sensitive data and thousands of user identities.

Existing Challenges

Many organizations lack automated methods to detect inactive, orphaned, expired, or overly privileged accounts. They also struggle to identify risky access behaviors occurring across multiple systems.

Another challenge is the lack of explainability. While security tools generate alerts, they often fail to clearly explain the reason for the alert, its impact, and the recommended actions.

Additionally, poor risk prioritization causes security teams to treat all alerts with equal urgency, leading to alert fatigue and delayed responses to critical threats.

The proposed Identity Threat Intelligence Platform addresses these challenges through automated identity risk detection, behavioral analysis, explainable insights, and intelligent risk prioritization.

1. Platform Architecture

An identity threat intelligence platform (ITIP) offers an organization solutions to identify identity sprawl and uncover orphaned accounts, stale privileged accounts, over-privileged users, and suspicious access activity across their enterprise. The solution provides a complete end-to-end workflow enabled through the integration of synthetic data generation, anomaly detection, explainable artificial intelligence (AI), performance evaluation, and interactive security operations centre (SOC) dashboards.

Architecture Workflow

Data Generation and Enrichment Layer

Identity and access dataset(s) of user account information and security event logs serve as the starting point for this platform. The `generate_data.py` module creates security-related features within the datasets and adds realistic identity threat examples such as:

- Stale administrator accounts
- Orphaned accounts
- Users with over-privileged accounts
- High risk access events
- Exporting of sensitive data

The module will also generate ground-truth labels that will be used to evaluate and validate models.

Detection Engine Layer

The detection capabilities are in `detector.py`.

The main functions of this module include:

1. Feature creation
2. Assigning risk (risk score)
3. Identifying unusual behaviours
4. Reducing false positives, and
5. Enforcing security rules on the identified threats.

This engine uses:

1. Isolation forest (to identify unusual behaviours)
2. Overrides or rules to detect critical threats, and
3. Hard exclusions for legitimate business activities (e.g., users who have a legitimate reason to have access).

Output files created by the engine are:

1. `flagged_users.csv`
2. `flagged_events.csv`

They contain all the threats identified based on identity and privilege.

Explainable AI Layer

The `Explainer.py` module increases transparency, and provides users with detailed security explanations (through the Groq LLM API) for flagged users and events. Examples include:

- Risk Assessment
- Blast Radius Estimation
- Compliance Impact Assessment
- Investigation Findings
- Suggested Remediation Steps

The explanations generated are both saved in an `explanations.json` file and displayed on the analyst's dashboard.

Evaluation Layer

The `evaluation.py` module compares model predictions against ground-truth labels.

It calculates:

- Precision
- Recall
- F1-Score
- Confusion Matrix
- False Positive Analysis

An audit report is automatically generated to assess model effectiveness and detection quality.

Visualization Layer

The Flask-based dashboard implemented in `app.py` serves as the Security Operations Center (SOC) interface.

It provides:

- Real-time security monitoring
- Risk analytics
- User investigations
- Event analysis
- Breach simulation
- Interactive visualizations

The dashboard acts as the primary interface between analysts and the detection system.

2. Analysis Algorithms

The platform uses a hybrid detection strategy combining machine learning and rule-based security analytics.

A. User Risk Analysis

User identity analysis utilizes some of the following attributes or characteristics to identify anomalous user behavior(s):

- Inactive days
- Access privilege level
- Number of systems with access rights
- Contractor status
- New hire status
- Stale administrator indicators
- Orphaned account indicators
- Over-privileged access indicators

The Isolation Forest algorithm processes this feature vector to identify anomalies in user actions.

Critical User Detection Rules

The automatic flagging by the system includes:

Stale Administrator Accounts

High-risk accounts will be flagged for one of the following reasons:

- Accounts remain inactive (not used) for over 60 days, or
- The account has an Admin or Superadmin privilege level.

Orphaned Accounts

Users will be flagged for the following reasons:

- The user is inactive, disabled or terminated, or
- The user still has access permissions assigned.

Over-Privileged Users

Users will be flagged based on the below conditions:

- Low privilege role or
- Access to multiple high value systems.

These conditions will be enforced via hard override rules for the purposes of detecting critical threats.

B. Event Risk Analysis

Behavioral and Contextual Indicators are used to assess the security incident associated with End-User Access to Resources. The following features will be measured with each Security event:

- Access Time
- Weekend Activity
- After Hours Activity
- Accessed Record Volume
- External Data Destination
- Resource Sensitivity
- Cross-Departmental Access
- User Statistically Deviation

Your Model will determine which activities are abnormal or unusual according to the following:

- Significant Exports of Data
- Data Transfers to External Destination
- Access to Highly Sensitive Resources
- After Hours Activity
- Cross Functional Access Violations

The isolation forest algorithm will be applied to the event data to find anomalous patterns.

C. Risk Scoring Mechanism

Each detected anomaly contributes to an overall risk score.

The score considers:

- Privilege level
- System criticality
- Data sensitivity
- Behavioral anomalies
- Access violations

Users and events are classified into:

Risk Score	Severity
0 – 39	Low
40-59	Medium
60-79	Hugh
80-100	Criticle

The severity classification helps analysts prioritize investigations and incident response activities.

D. Explainable Security Analysis

For each flagged entity, the system generates:

- Risk findings
- Compliance violations
- Blast radius estimation
- Business impact assessment
- Remediation recommendations

Compliance mapping includes:

- NIST AC-2
- GDPR Article 32
- SOX 302

This improves analyst trust and supports regulatory auditing requirements.

3. User Interface Design

The platform provides a modern SOC-style dashboard built using Flask and Plotly.

The interface follows a dark-theme cybersecurity design optimized for security analysts and incident responders.

A. Command Center Dashboard



The landing page provides an executive overview of organizational identity risks.

Displayed metrics include:

- Total Users
- Anomalous Users
- Critical Alerts
- Systems at Risk
- Precision
- Recall
- F1 Score

Interactive charts visualize:

- Department-wise risk distribution
- Security event trends
- Severity breakdown
- Model performance metrics

This allows rapid assessment of organizational security posture.

B. User Investigation Module

- Event filtering
- Severity classification
- Resource sensitivity tracking
- Access pattern monitoring
- Timeline-based analysis

This enables analysts to quickly identify and investigate potentially malicious actions.

D. Breach Simulation Module



The platform includes a breach simulation environment.

This feature visualizes:

- Potential attack paths
- Privilege escalation chains
- Lateral movement opportunities
- Impact propagation

The simulation helps security teams understand potential attack consequences and prioritize remediation efforts.

E. Real-Time Security Feed

The dashboard includes a live threat feed that continuously displays:

- High-risk events
- Critical alerts
- User anomalies
- Suspicious activities

This provides SOC analysts with immediate visibility into ongoing security concerns.

LINKS

GITHUB

<https://github.com/chitramadarakhandi/Societegenerale-Hackthon.git>

VIDEO LINK

https://drive.google.com/file/d/1Dtz53Ck4GtrcvHSd7NlSBFdC_3k_DpUm/view?usp=sharing

Conclusion

The Identity Threat Intelligence Platform uses a mix of rules-based analytics, machine learning, explainable AI, performance assessment, and interactive visualization to help identify areas of the company (enterprise) where identity sprawl or excessive privilege abuse is happening. The platform provides an integration of Isolation Forest anomaly detection technology with compliance-sensitive risk assessment via SOC-style dashboards, Groq-powered explainability, and threat detection through anomaly detection techniques, among other things. Therefore, security teams can use the platform to recognize threats earlier and reduce their attack surface, as well as implement stronger governance of identities for the entire organization.